

AI Use Policy

Owner: [name / role] · **Last reviewed:** [May 2026] · **Next review:** [quarterly] · **Applies to:** everyone, contractors included
One page on purpose — a 40-page binder is one nobody reads. The leadership team follows this first; a policy the boss ignores is decoration.

THE 5-QUESTION GATE — RUN THIS BEFORE ANY NEW AI USE GOES LIVE

Most low-risk uses clear all five in under a minute. Can't answer one? That's your stop sign — sanction it through the request path below.

01
Owner

Who is the named human accountable for the output? No name, no go.

02
Data

What data does it touch — and is that data allowed in this tool?

03
Stakes

Does it decide about a person, money, or regulated data? If yes, who signs off?

04
Cost & value

What's the success metric — and when do we kill it if it misses?

05
Exposure

Does any output reach a regulated market or customer? Do we know the rules?

1 Acceptable useWHAT AI IS FOR

✓ Encouraged:

drafting, summarizing, research, brainstorming, code assistance, and analysis on approved data.

✗ The short "no" list

(memorize it): no Confidential data in non-approved tools · AI never makes the final call on a person, payment, or legal matter without a named human · don't ship AI output as fact unchecked · no personal accounts for company work.

2 Data handlingBY CLASSIFICATION

The one rule everyone must remember:

• Public

(published material) → any sanctioned tool.

• Internal

(ops docs, plans) → approved enterprise tools only.

• Confidential

(customer/employee PII, financials, source code, secrets, regulated data) → only approved enterprise tool with signed DPA + no-training terms . Never free/consumer tiers.

3 Tool allowlistSANCTION, DON'T BAN

Approved today:

[ChatGPT Enterprise], [Claude Team], [Copilot Business], [Gemini for Workspace].

New tool, model, or MCP integration?

Request via #ai-requests / this form — decision in [2 business days] .

The fast path is what keeps an allowlist from becoming a ban.

4 Human-in-the-loopMATCH LEASH TO STAKES

• Green

— AI runs unsupervised: internal drafts, brainstorming, code suggestions.

• Yellow

— a human reviews before it leaves the building: customer comms, external content, analysis feeding a decision.

• Red

— a named human signs off & it's logged: deciding about a person (hiring, performance, credit), money over [\$X], or regulated/legal output.

Let the memo run; sign off on the loan.

5 Vendor ruleIT LIVES IN THE CONTRACT

For anything touching Internal or Confidential data:

• Enterprise / API tier

— not the consumer free tier.

• No-training & retention/deletion terms confirmed.

• DPA signed · data residency checked.

• Security review before any tool touches Confidential data.

DPA = the contract that makes "no-training" and deletion legally binding.

6 Incident pathNO BLAME

A leak, a bad output that shipped, suspected prompt injection, or just something weird?

→ Tell [security@company.com / #ai-incidents / owner] the same business day.

Reporting a near-miss is a win. Blame drives incidents underground — we'd rather hear it than find it.